

2018-03-10 TRAFFIC ANALYSIS EXERCISE: ANSWERS

"MAX HEADROOM"

www.malware-traffic-analysis.net/2018/03/10/2018-03-10-traffic-analysis-exercise.pcap.zip

The zip file is password-protected with the standard password. See the "about" page of my site if you don't know it.

YOUR TASK:

Review the pcap, and document the following:

- Date and time of the malicious activity in UTC (GMT).
- IP address of the affected Windows host.
- Mac address of the affected Windows host.
- Host name of the affected Windows host.
- User account name on the affected Windows host.
- What happened.

ANSWERS:

- Date/Time: 2018-03-10 at approximately 05:28 UTC
- IP address: 172.16.1.138
- Mac address: 00:0b:cd:e0:71:53 (HewlettP_e0:71:53)
- Host name: SHAXTAL-PC
- User account name: bruno.shaxtal
- What malware might be involved: infection due to the [Boleto Mestre malspam campaign](#)

DETAILS

As always, I recommend you set up Wireshark according to the tutorials I've documented at:

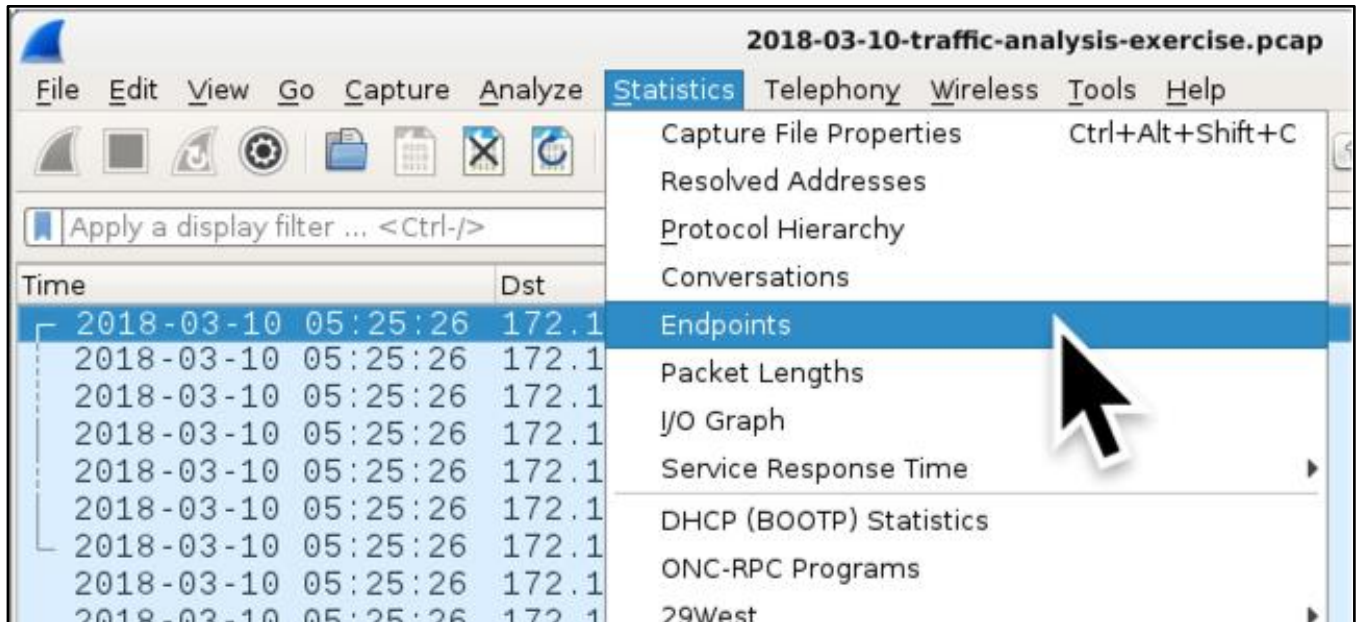
- <http://malware-traffic-analysis.net/tutorials/index.html>

This pcap was taken from traffic on an internal network for **max-headroom.com**. Not counting the domain controller, 3 different clients are active in this pcap. The associated IP addresses are:

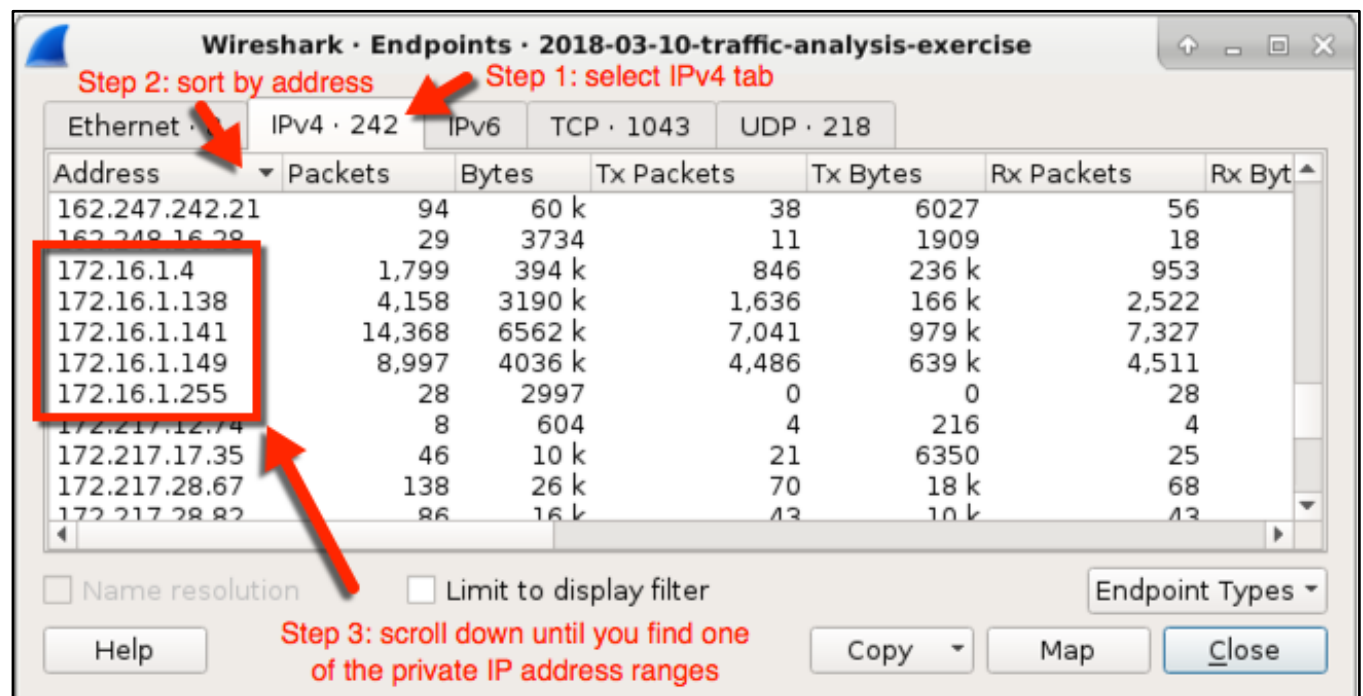
- LAN segment: 172.16.1.0/24 (172.16.1.0 through 172.16.1.255)
- Broadcast address for this LAN segment: 172.16.1.255
- Domain controller for **max-headroom.com**: 172.16.1.4
- Windows client - 00:0b:cd:e0:71:53 (SHAXTAL-PC): 172.16.1.138
- Apple MacBook client - c8:2a:14:fb:3e:13 (Jessica-MacBook): 172.16.1.149
- Samsung android phone - 4c:66:41:96:14:a8 (host name unknown): 172.16.1.141

2018-03-10 TRAFFIC ANALYSIS EXERCISE: ANSWERS

When you have a pcap of unknown traffic (like these exercises), I suggest you check the Endpoints section under the Statistics menu and search for all internal IP addresses. You'll look for anything in the 10.0.0.0/8 range (10.0.0.1 through 10.255.255.255), 172.16.0.0/12 range, (172.16.0.1 through 172.31.255.255), or 192.168.0.0/16 range (192.168.0.1 through 192.168.255.255). These are Class A, B, and C non-routable IPv4 addresses used internally within a networked environment.



Shown above: Getting to the endpoints data



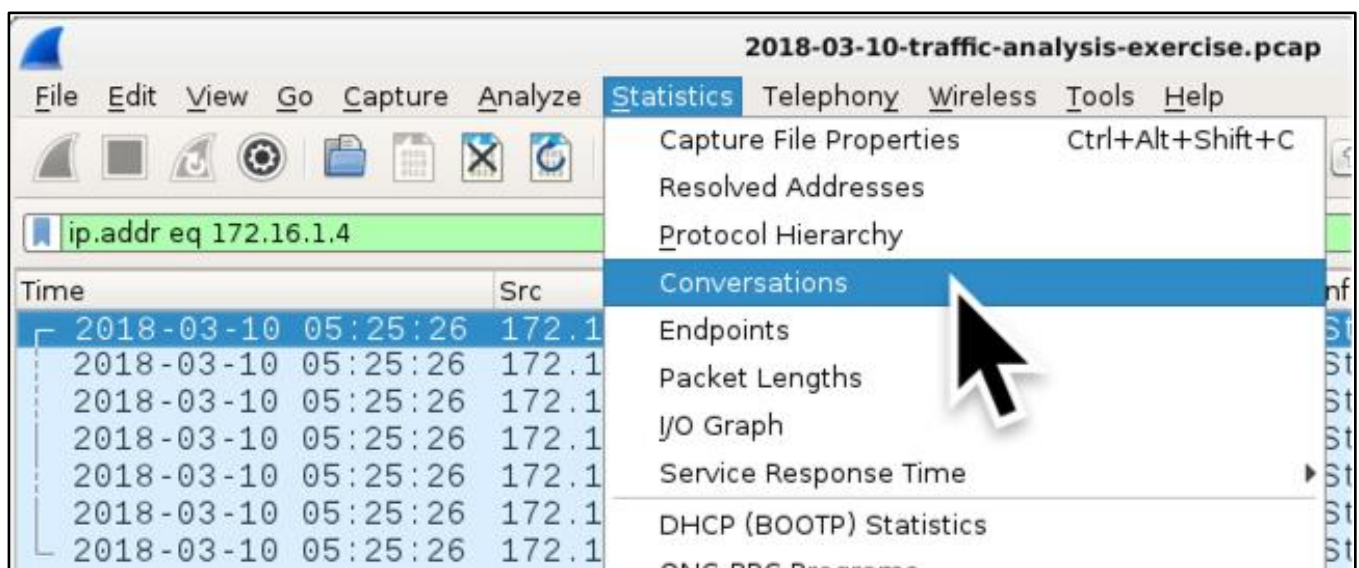
Shown above: Finding a private IP range for the internal network IP addresses.

2018-03-10 TRAFFIC ANALYSIS EXERCISE: ANSWERS

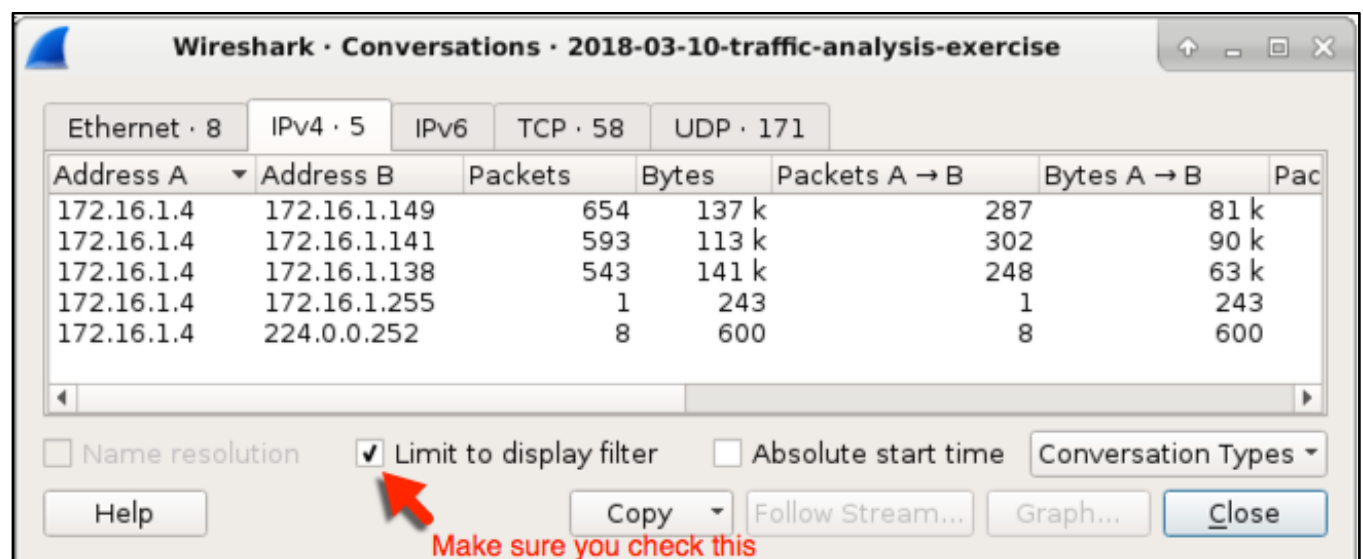
In this exercise pcap, you'll find the following:

- 172.16.1.4
- 172.16.1.138
- 172.16.1.141
- 172.16.1.149
- 172.16.1.255

172.16.1.255 is the broadcast IP address, and it doesn't represent any specific host. The other four IP addresses are all hosts on the internal network. If you filter on 172.16.1.4, you'll find it primarily communicates with the other internal IP addresses. That's one of many indicators it's a domain controller for an internal network with a Windows-based infrastructure.



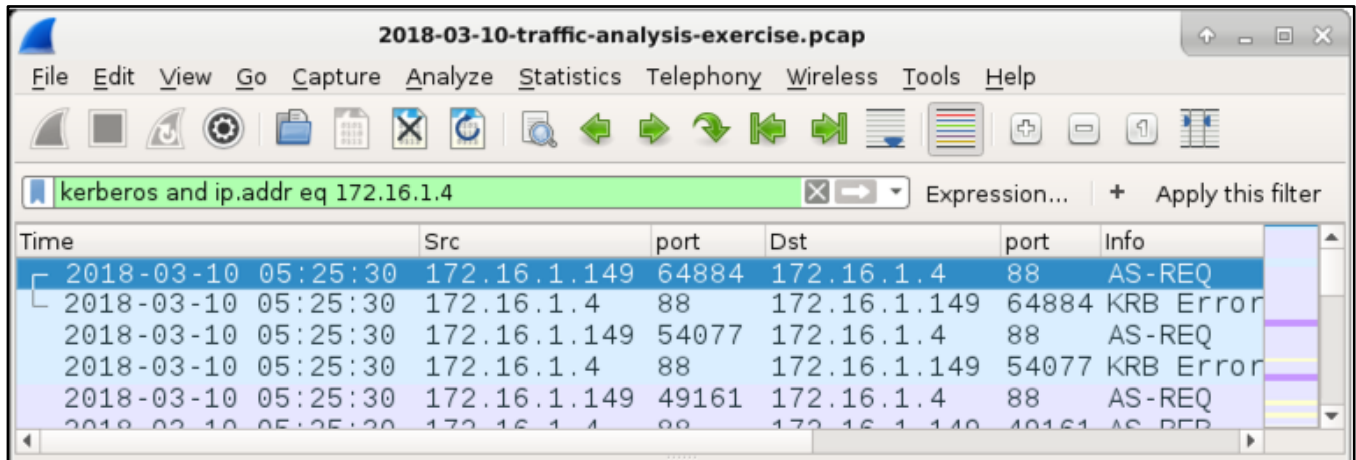
Shown above: Filtering on 172.16.1.4 and finding the conversations.



Shown above: Viewing conversations limiting to the display filter shows mostly internal IPs.

2018-03-10 TRAFFIC ANALYSIS EXERCISE: ANSWERS

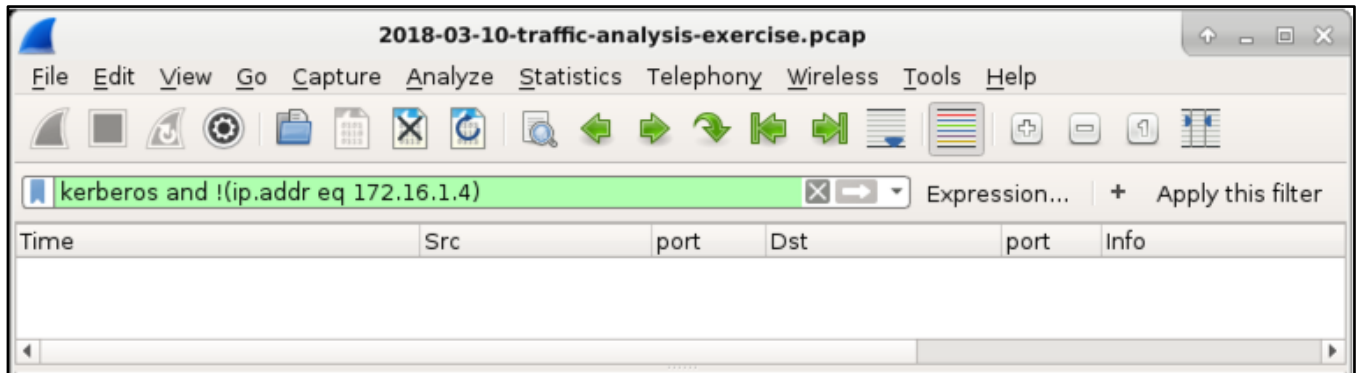
Another indicator for 172.16.1.4 being a domain controller? Kerberos traffic that clients use to authenticate as they log into the internal network.



The screenshot shows the Wireshark interface with the filter 'kerberos and ip.addr eq 172.16.1.4'. The packet list contains several Kerberos AS-REQ and KRB Error messages between 172.16.1.149 and 172.16.1.4.

Time	Src	port	Dst	port	Info
2018-03-10 05:25:30	172.16.1.149	64884	172.16.1.4	88	AS-REQ
2018-03-10 05:25:30	172.16.1.4	88	172.16.1.149	64884	KRB Error
2018-03-10 05:25:30	172.16.1.149	54077	172.16.1.4	88	AS-REQ
2018-03-10 05:25:30	172.16.1.4	88	172.16.1.149	54077	KRB Error
2018-03-10 05:25:30	172.16.1.149	49161	172.16.1.4	88	AS-REQ
2018-03-10 05:25:30	172.16.1.4	88	172.16.1.149	49161	AS-REQ

Shown above: Filtering on Kerberos involving 172.16.1.4.

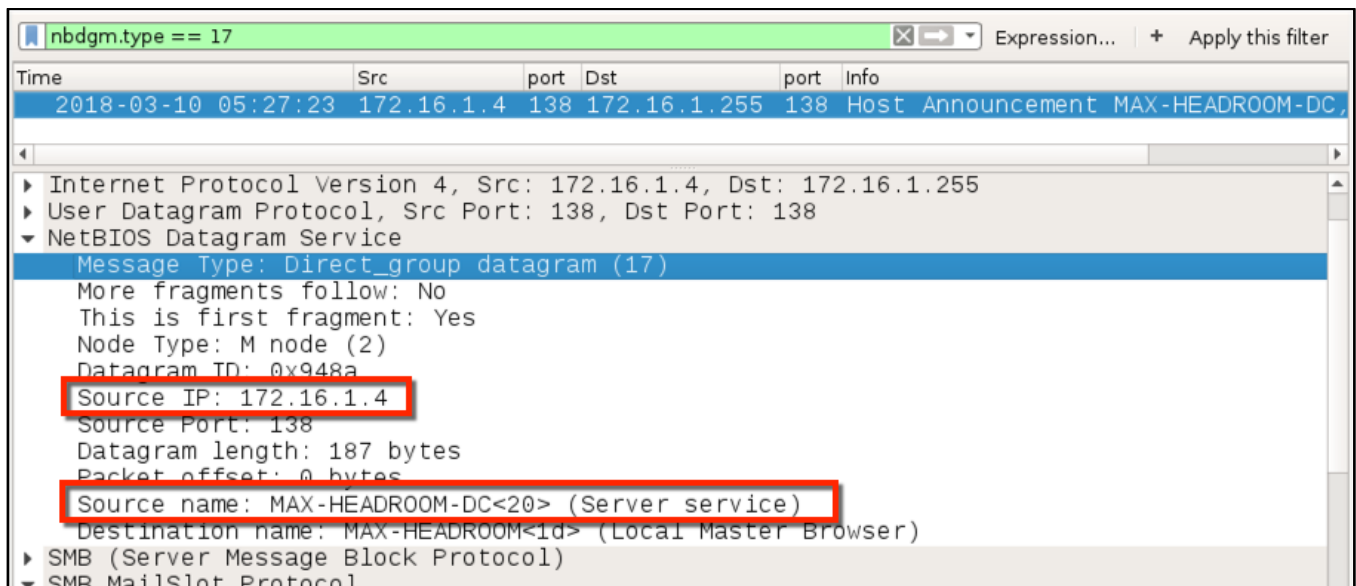


The screenshot shows the Wireshark interface with the filter 'kerberos and !(ip.addr eq 172.16.1.4)'. The packet list is empty, indicating no traffic matches the filter.

Time	Src	port	Dst	port	Info
------	-----	------	-----	------	------

Shown above: Filtering on Kerberos without 172.16.1.4 shows no other hosts.

Other traffic related to domain controllers provides further indicators. Filtering on **udp.port eq 138** or **nbdgm.type == 17** reveals a NetBIOS host announcement for **MAX-HEADROOM-DC**.



The screenshot shows the Wireshark interface with the filter 'nbdgm.type == 17'. The packet list shows a NetBIOS host announcement from 172.16.1.4 to 172.16.1.255. The packet details pane shows the message type as 'Direct_group datagram (17)' and the source name as 'MAX-HEADROOM-DC<20> (Server service)'.

Time	Src	port	Dst	port	Info
2018-03-10 05:27:23	172.16.1.4	138	172.16.1.255	138	Host Announcement MAX-HEADROOM-DC

Internet Protocol Version 4, Src: 172.16.1.4, Dst: 172.16.1.255
User Datagram Protocol, Src Port: 138, Dst Port: 138
NetBIOS Datagram Service
Message Type: Direct_group datagram (17)
More fragments follow: No
This is first fragment: Yes
Node Type: M node (2)
Datagram ID: 0x948a
Source IP: 172.16.1.4
Source Port: 138
Datagram length: 187 bytes
Packet offset: 0 bytes
Source name: MAX-HEADROOM-DC<20> (Server service)
Destination name: MAX-HEADROOM<1d> (Local Master Browser)
SMB (Server Message Block Protocol)
SMB MailSlot Protocol

Shown above: NetBIOS host announcement showing 172.16.1.4 is MAX-HEADROOM-DC.

2018-03-10 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Our next step? Let's look at the other IP addresses, starting with 172.16.1.138.

- 172.16.1.4 - MAX-HEADROOM-DC
- 172.16.1.138 - ?? ← (up next)
- 172.16.1.141 - ??
- 172.16.1.149 - ??
- 172.16.1.255 - broadcast address

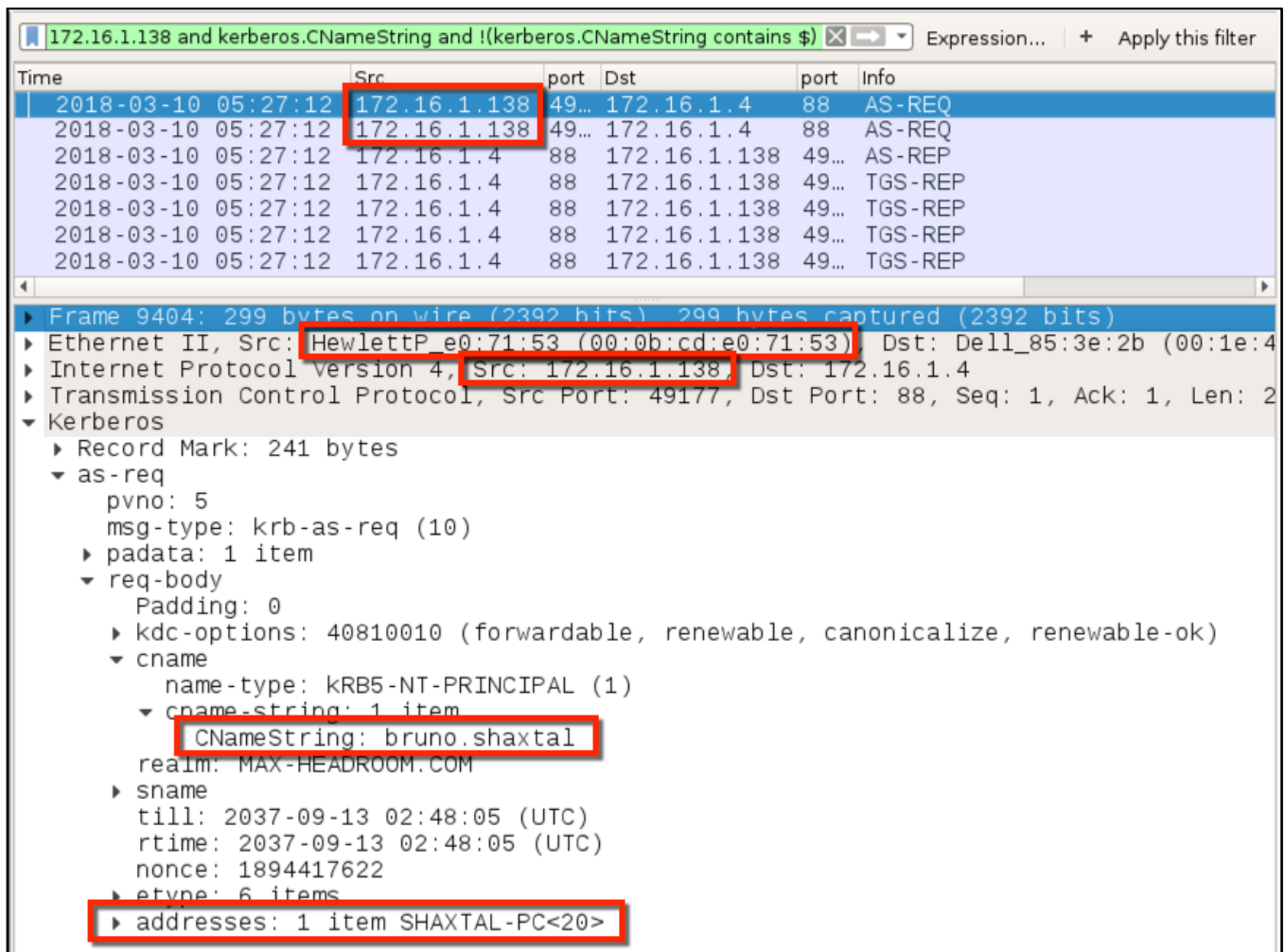
Checking an IP address for Kerberos authentication traffic is a quick way to see if that IP is a Windows host, and you can also get the user account name. For recent Wireshark versions (2.2 and greater), use the following filter:

ip.addr eq 172.16.1.138 and kerberos.CNameString and !(kerberos.CNameString contains \$)

For older versions of Wireshark (1.12 and lower), use the following filter:

ip.addr eq 172.16.1.138 and kerberos.cname_element and kerberos.KerberosString and !(kerberos.KerberosString contains \$)

This quickly shows us 172.16.1.138 is ***bruno.shaxtal*** on ***SHAXTAL-PC***.



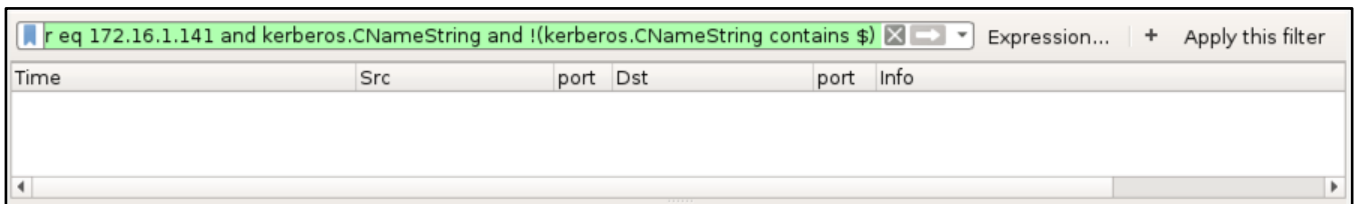
Shown above: Kerberos traffic showing 172.16.1.138 is ***bruno.shaxtal*** on ***SHAXTAL-PC***.

2018-03-10 TRAFFIC ANALYSIS EXERCISE: ANSWERS

So with that one filter, we found out the MAC address, Windows host name, and user account name for 172.16.1.138. Will we be as lucky with the other two? Let's check 172.16.1.141 next.

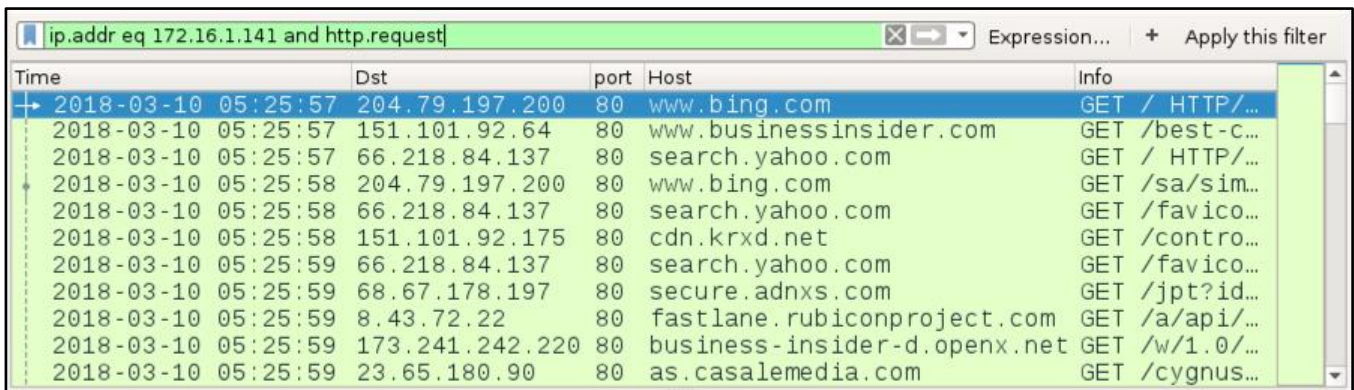
- 172.16.1.4 - MAX-HEADROOM-DC
- 172.16.1.138 - SHAXTAL-PC
- 172.16.1.141 - ?? ← (up next)
- 172.16.1.149 - ??
- 172.16.1.255 - broadcast address

Try that same filter with 172.16.1.141, and we aren't so lucky. No results come up. In fact, there's no Kerberos traffic for 172.16.1.141 at all.



Shown above: No luck using the same filter for 172.16.1.141.

You also won't find any NBNS traffic, which indicates this host is not running Windows. There is also no DHCP traffic to gather any other host-related identification. My "go to" default filter for these situations is **http.request** combined with that IP. In this case, we see over 300 HTTP GET requests from 172.16.1.141 to various domains.



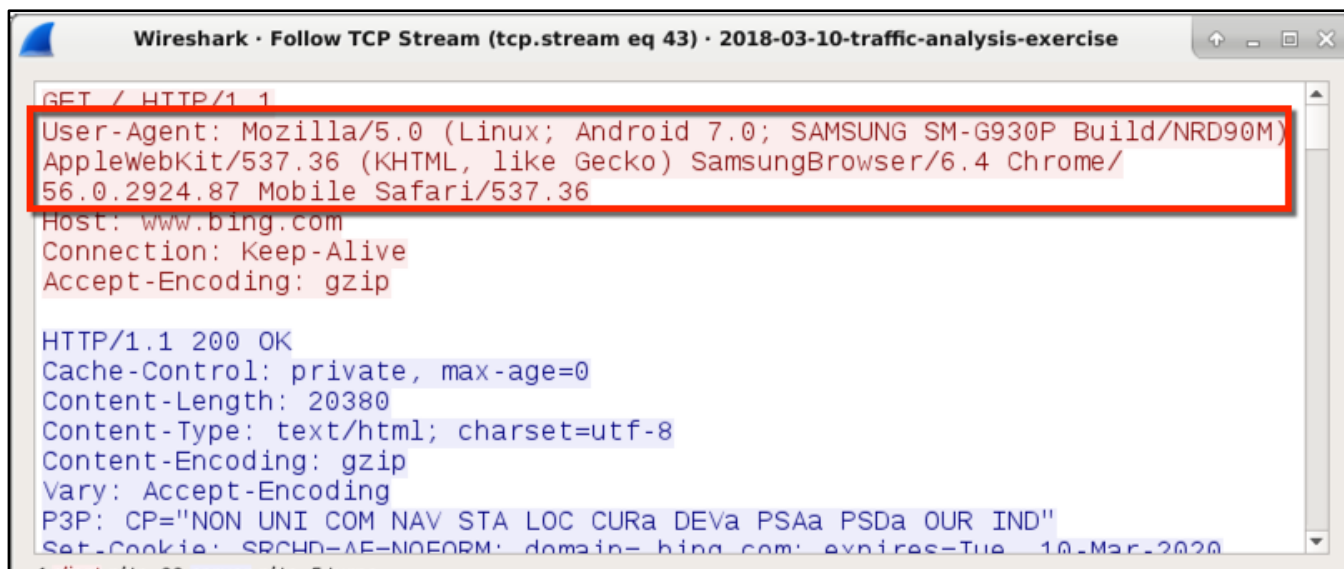
Shown above: Many requests seen filtering with **ip.addr eq 172.16.1.141 and http.request**

Let's follow the TCP stream for the first HTTP GET request and look at the user-agent. When you do, you'll see the following:

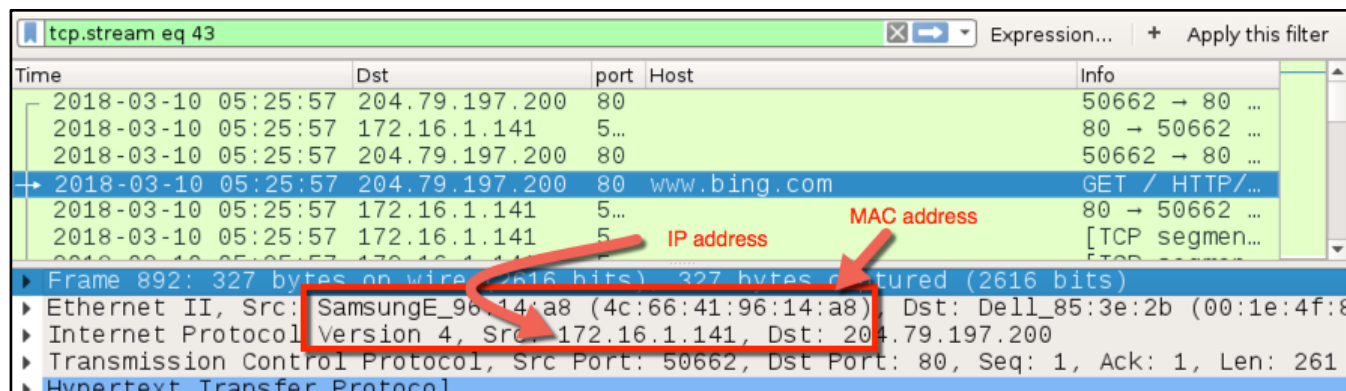
User-Agent: Mozilla/5.0 (Linux; Android 7.0; SAMSUNG SM-G930P Build/NRD90M) AppleWebKit/537.36 (KHTML, like Gecko) SamsungBrowser/6.4 Chrome/56.0.2924.87 Mobile Safari/537.36

This indicates 172.16.1.141 is an Android device. The model number is Samsung SM-G930P, which a Google search shows is a Galaxy S7 phone.

2018-03-10 TRAFFIC ANALYSIS EXERCISE: ANSWERS



Shown above: User-agent string showing this is a Samsung SM-G930P (Galaxy S7).



Shown above: Trying the MAC address to the IP.

Only one more left. Let's check 172.16.1.149 next. Let's try that first Kerberos filter we used to find a user account name earlier.

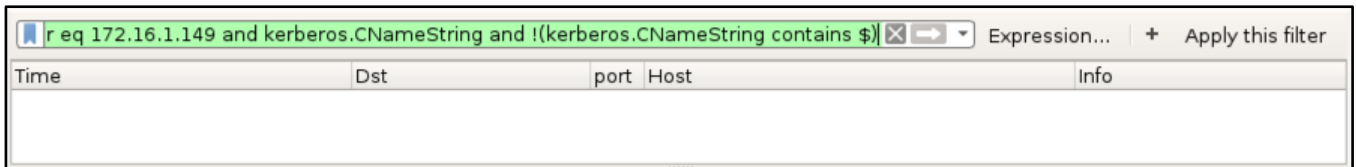
- 172.16.1.4 - MAX-HEADROOM-DC
- 172.16.1.138 - SHAXTAL-PC
- 172.16.1.141 - Samsung Galaxy S7
- 172.16.1.149 - ?? ← (up next)
- 172.16.1.255 - broadcast address

The filter is:

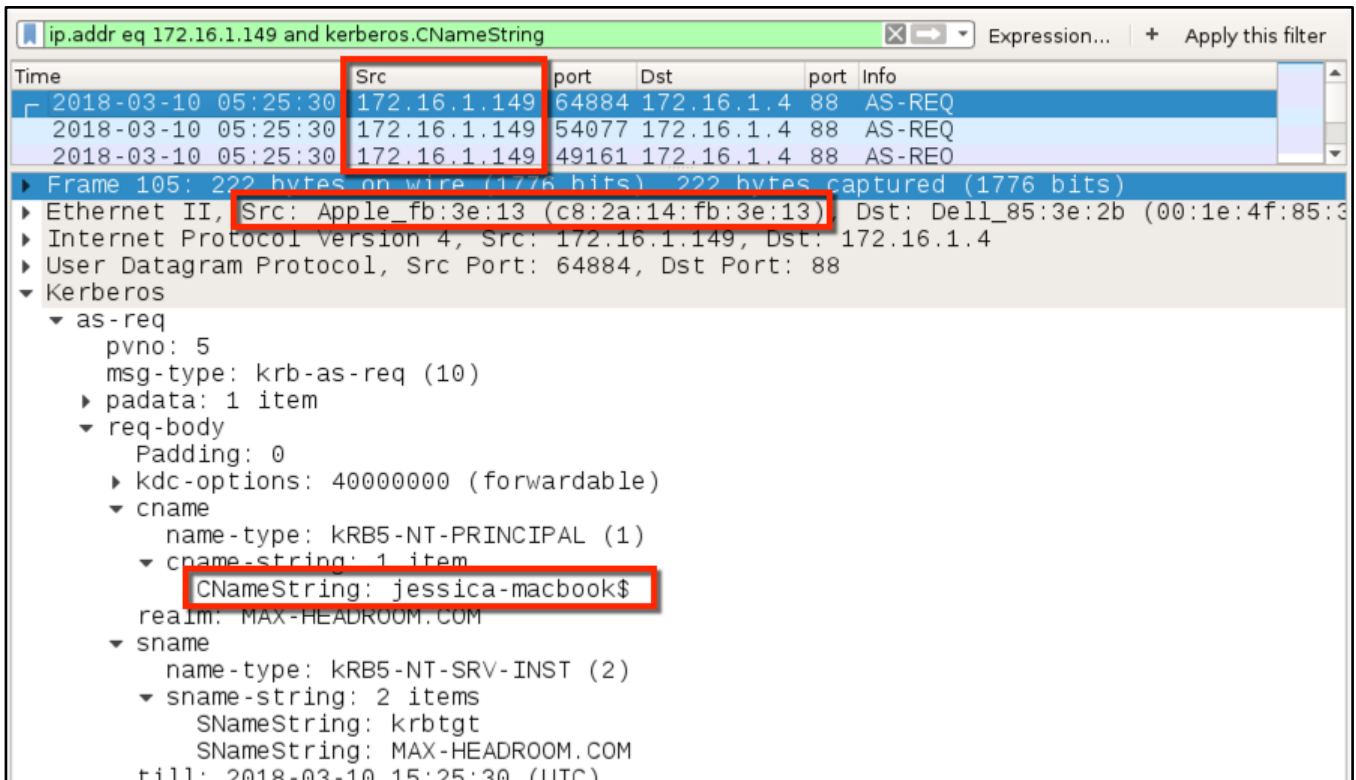
ip.addr eq 172.16.1.149 and kerberos.CNameString and !(kerberos.CNameString contains \$)

Unfortunately, we don't get any results. However, we do have some Kerberos traffic with 172.16.1.149, so let's just filter on ***ip.addr eq 172.16.1.149 and kerberos.CNameString*** because CNameStrings ending with \$ are host names, which were filtered out when we used that previous Wireshark filter.

2018-03-10 TRAFFIC ANALYSIS EXERCISE: ANSWERS



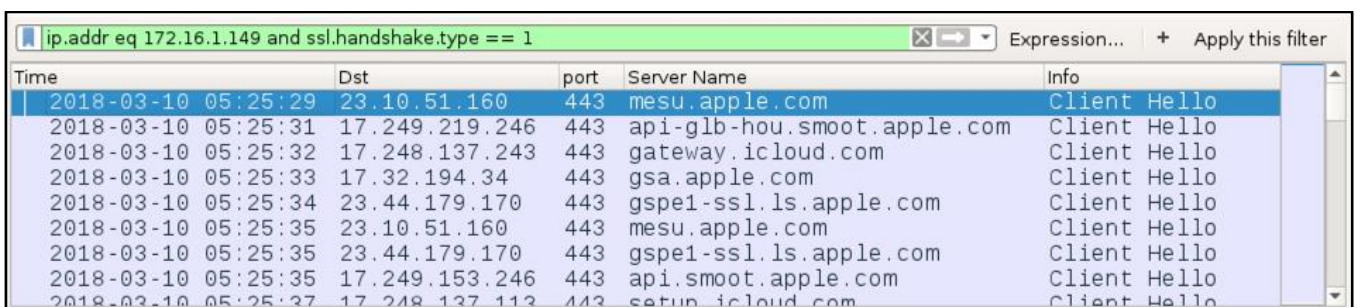
Shown above: No luck with 172.16.1.149 when filtering for a user account name.



Shown above: Adjusting the filter allows us to find a host name associated with 172.16.1.149.

As seen above, the host name is **jessica-macbook** and the MAC address indicates this is an Apple product. This is likely a MacBook. We find the same information when looking at NBNS traffic when filtering on **ip.addr eq 172.16.1.149 and nbns**.

The HTTPS traffic shows several Apple-related domains, so we can safely assume this is indeed a MacBook. Unfortunately, we have no HTTP traffic with a user-agent string for more information on this host.



Shown above: HTTPS traffic shows communication from 172.16.1.149 to many Apple domains.

2018-03-10 TRAFFIC ANALYSIS EXERCISE: ANSWERS

The image shows a Wireshark packet capture window with the filter `ip.addr eq 172.16.1.149 and nbns`. The packet list shows several NetBIOS Name Service (NBNS) packets. The selected packet (Frame 390) is a NetBIOS Name Service Registration packet. The packet details pane shows the following information:

- Ethernet II, Src: Apple_fb:3e:13 (c8:2a:14:fb:3e:13), Dst: Broadcast (ff:ff:ff:ff:ff:ff)
- Internet Protocol version 4, Src: 172.16.1.149, Dst: 172.16.1.255
- User Datagram Protocol, Src Port: 137, Dst Port: 137
- NetBIOS Name Service
 - Transaction ID: 0x4567
 - Flags: 0x2910, Opcode: Registration, Recursion desired, Broadcast
 - Questions: 1
 - Answer RRs: 0
 - Authority RRs: 0
 - Additional RRs: 1
 - Queries
 - Additional records
 - JESSICA-MACBOOK<00>: type NB, class IN
 - Name: JESSICA-MACBOOK<00> (Workstation/Redirector)
 - Type: NB (32)
 - Class: IN (1)
 - Time to live: 15 minutes
 - Data length: 6
 - Name flags: 0x6000, ONT: Unknown (H-node, unique)
 - Addr: 172.16.1.149

Shown above: Filtering on NBNS traffic gives us the same host identification.

Now we know who everyone is on the internal network.

- 172.16.1.4 - MAX-HEADROOM-DC
- 172.16.1.138 - SHAXTAL-PC
- 172.16.1.141 - Samsung Galaxy S7
- 172.16.1.149 - jessica-macbook
- 172.16.1.255 - broadcast address

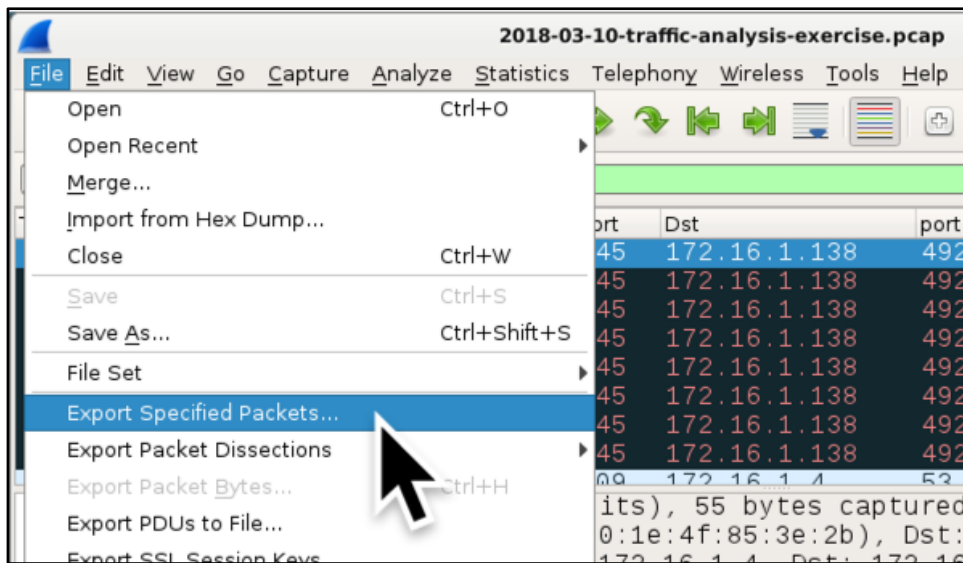
The only Windows client on this network is SHAXTAL-PC, so let's focus on that. Let's filter in Wireshark on `ip.addr eq 172.16.1.138` and export those packets to a new pcap.

The image shows a Wireshark packet capture window with the filter `ip.addr eq 172.16.1.138`. The packet list shows several TCP packets. The selected packet (Frame 1) is a TCP Keep-Alive message. The packet details pane shows the following information:

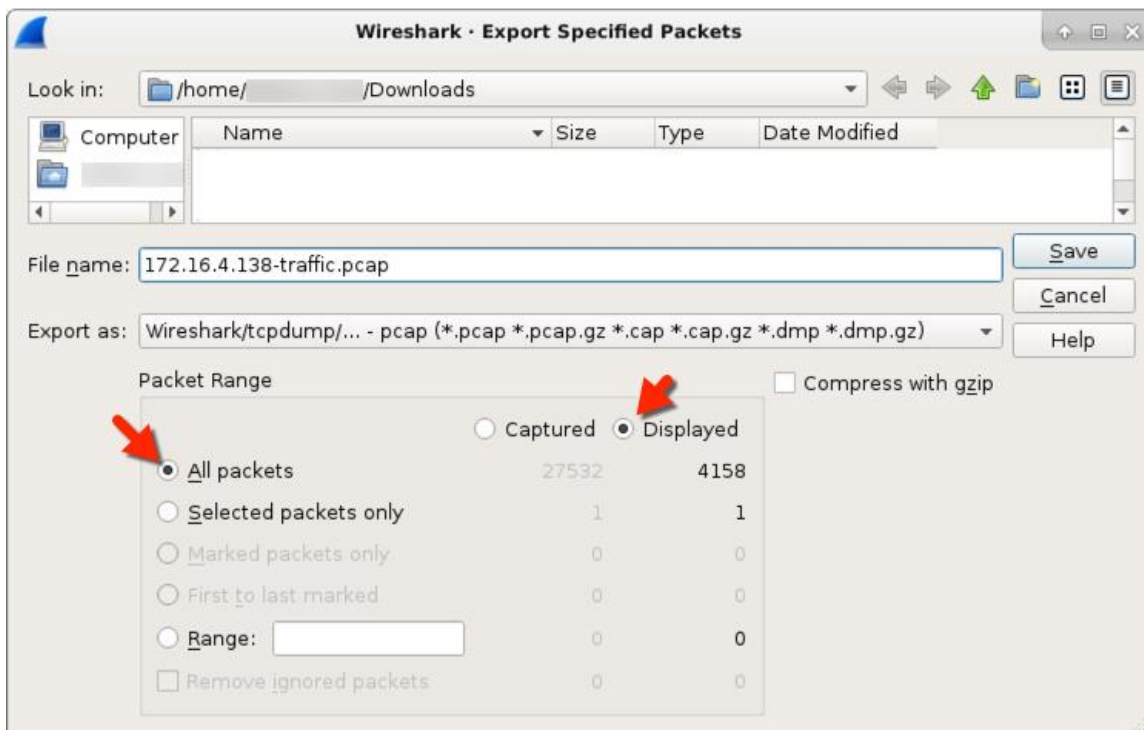
- Ethernet II, Src: Apple_fb:3e:13 (c8:2a:14:fb:3e:13), Dst: 172.16.1.138
- Internet Protocol version 4, Src: 172.16.1.4, Dst: 172.16.1.138
- TCP, Src Port: 445, Dst Port: 49277
- Application Layer: [TCP Keep-Alive]

Shown above: Filtering on `ip.addr eq 172.16.1.138`.

2018-03-10 TRAFFIC ANALYSIS EXERCISE: ANSWERS



Shown above: Exporting those filtered packets to a new pcap.



Shown above: Let's save it as **172.16.4.138-traffic.pcap**

I submitted this new pcap to PacketTotal at:

- <https://packettotal.com/app/analysis?id=2e8b95636daf64eba0e22f1ecd130791>

The alerts only indicate a suspicious **.top** domain. Let's look at the HTTP requests and see if this information leads us anywhere. The **.top** domain is **www.b3llavit4.top**, which shows up on a Google search.

2018-03-10 TRAFFIC ANALYSIS EXERCISE: ANSWERS

http.request						Expression...	Apply this filter
Time	Dst	port	Host	Info			
2018-03-10 05:27:19	23.65.180.72	80	www.msftncsi.com	GET /ncsi.txt HTTP/1.1			
2018-03-10 05:27:39	65.181.125.162	80	servicodeentrega.x...	GET /14022018000000313376169901243556...			
2018-03-10 05:27:46	23.65.180.96	80	acroipm.adobe.com	GET /10/rdr/ENU/win/nooem/none/messag...			
2018-03-10 05:28:42	65.181.125.161	80	65.181.125.161	GET /2018a/aw7.tiff HTTP/1.1			
2018-03-10 05:28:44	65.181.125.161	80	www.b3llavit4.top	GET /avs/index.php?N=SHAXTAL-PC-bruno...			
2018-03-10 05:28:45	65.181.125.161	80	www.b3llavit4.top	GET /avs/logs/index.php?N=SHAXTAL-PC-...			
2018-03-10 05:28:45	65.181.125.161	80	www.b3llavit4.top	GET /avs/logs/index.php?N=SHAXTAL-PC-...			
2018-03-10 05:28:45	65.181.125.161	80	www.b3llavit4.top	GET /avs/logs/index.php?N=SHAXTAL-PC-...			
2018-03-10 05:28:46	65.181.125.161	80	www.b3llavit4.top	GET /avs/logs/index.php?N=SHAXTAL-PC-...			
2018-03-10 05:28:46	65.181.125.161	80	www.b3llavit4.top	GET /avs/logs/index.php?N=SHAXTAL-PC-...			
2018-03-10 05:28:46	65.181.125.161	80	65.181.125.161	GET /2018a/w7.zip HTTP/1.1			
2018-03-10 05:28:52	65.181.125.161	80	www.b3llavit4.top	GET /avs/logs/index.php?N=SHAXTAL-PC-...			
2018-03-10 05:28:52	65.181.125.161	80	65.181.125.161	GET /2018a/dll.dll HTTP/1.1			
2018-03-10 05:28:53	65.181.125.161	80	www.b3llavit4.top	GET /avs/logs/index.php?N=SHAXTAL-PC-...			
2018-03-10 05:28:53	65.181.125.161	80	www.b3llavit4.top	GET /avs/logs/index.php?N=SHAXTAL-PC-...			

Shown above: From the HTTP requests, the .top domain is **www.b3llavit4.top**.

The screenshot shows a Google search interface with the query "www.b3llavit4.top". The search results are displayed below the search bar, showing "About 7 results (0.27 seconds)". The first result is titled "Malware-Traffic-Analysis.net - 2018-03-05 - Malspam from the Boleto ..." and includes a URL and a snippet of text. The second result is titled "PacketTotal - 7ffbd11aa2ce072dc41838cd1ac5adb1 Analysis" and includes a URL and a snippet of text. The third result is titled "Free Automated Malware Analysis Service ... - Hybrid Analysis" and includes a URL and a snippet of text.

Shown above: Some results from a Google search.

One of the entries is a blog I posted earlier in March 2018 on the Boleto Mestre campaign. Another result is analysis of a specific file on **hybrid-analysis.com** that generated traffic to **www.b3llavit4.top**. This should give you enough information to figure out the type of email that Bruno Shaxtal originally received to kick off the infection chain of events.